TASK: 9

SQL Injection

Surendra Gabbani

What is SQL injection?

SQL injection is a class of web application vulnerability where an attacker is able to send crafted input that changes the structure of SQL queries your app sends to the database. That can allow data theft, data modification, authentication bypass, or full system compromise

Types of SQLi:

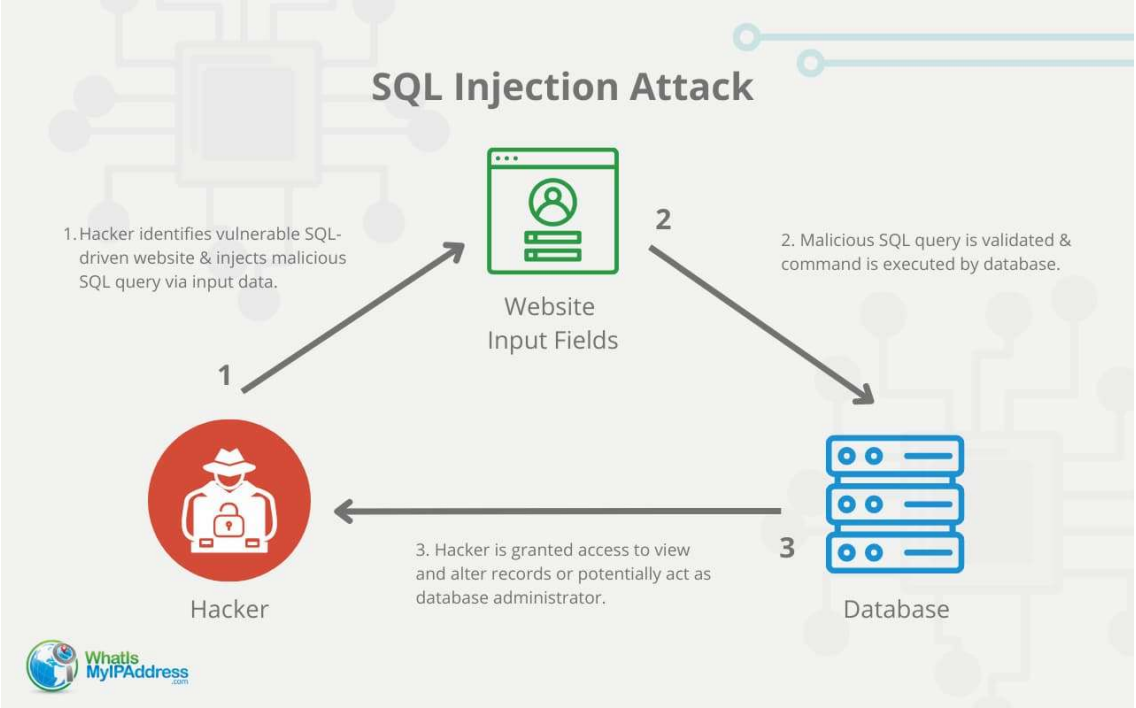
1. **In-band (direct)**
    - *Union-based* — use UNION SELECT to fetch data from other tables.
    - *Error-based* — craft input that forces DB errors revealing info.
2. **Inferential (blind)** — no data returned directly; attacker infers results:
    - *Boolean-based* — send payloads that yield true/false and infer bits.
    - *Time-based* — use DB sleep/delay to infer results.
3. **Out-of-band** — use features (e.g., DNS/http requests from DB) to retrieve data when other channels are blocked.

Demo payloads (safe, illustrative):

- Authentication bypass: ' OR '1'='1' --
- Error-based data retrieval: UNION SELECT username, password FROM users --
- Boolean blind: 1' AND (SELECT SUBSTRING(password,1,1) FROM users WHERE username='admin') = 'a' --
- Time-based: ' OR IF(SUBSTRING(password,1,1)='a', SLEEP(5), 0) --

How to find SQLi:

- Manual tests: try single-quote (') to provoke errors, boolean queries, time delays.
- Automated tools: **sqlmap**, Burp Suite (intruder/scanner), manual proxy + payload lists.
- Code review: look for string concatenation building SQL with user input.



How it works (example):

- Vulnerable code :
  query = "SELECT * FROM users WHERE username = '" + user + "' AND password = '" + pass + "'";
- Malicious input: user = ' OR '1'='1 → authentication bypass.

Lab & Practice

Lab: SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

APPRENTICE

This lab contains a SQL injection vulnerability in the product category filter. When the user selects a category, the application carries out a SQL query like the following:

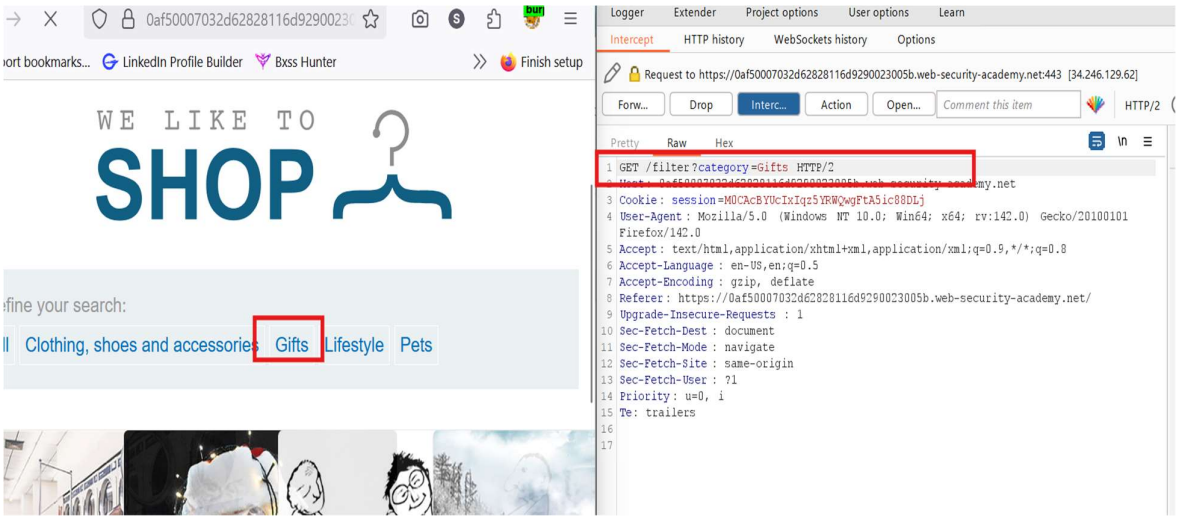
```
SELECT * FROM products WHERE category = 'Gifts' AND relea
```

To solve the lab, perform a SQL injection attack that causes the application to display one or more unreleased products.

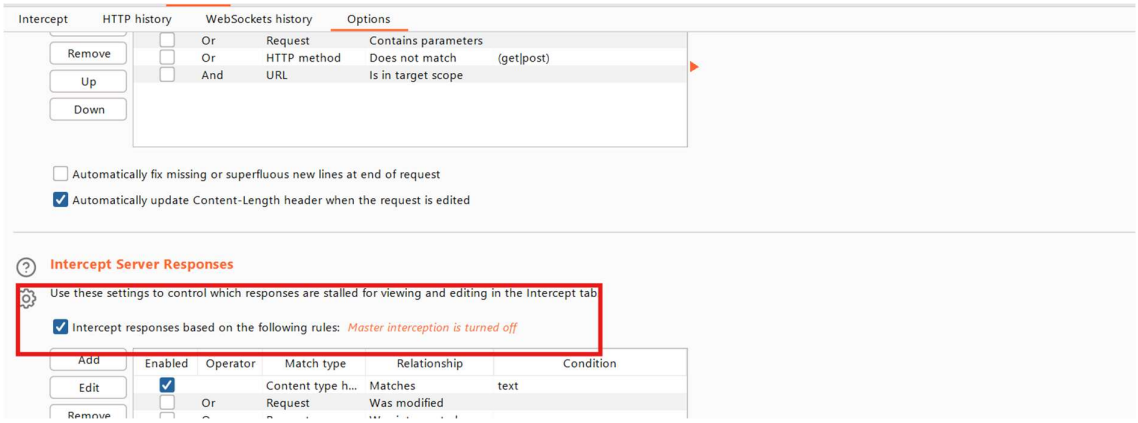
ACCESS THE LAB

STEP 1:

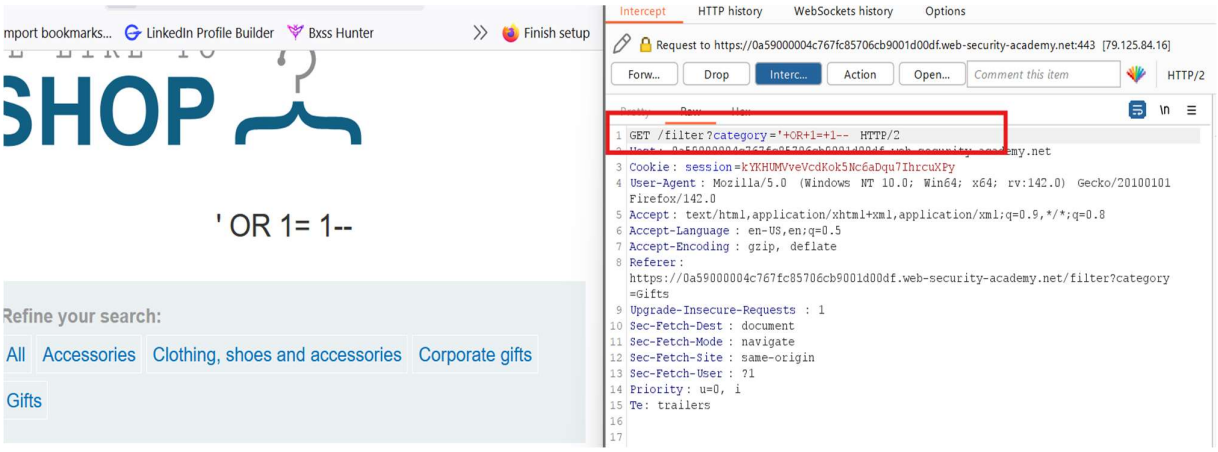
(Turn on the burpsuite and interceptor ON and capture the request)



STEP 2: (Give the checkmark for interceptor server responses)



STEP3:(Give the payload inputs to inject the website)



STEP4: Solved

Mitigation: Defensive Coding:

- Use prepared statements / parameterized queries (no string concatenation)
- Use stored procedures carefully (still need parameterization)
- Input validation and output encoding
- Principle of least privilege for DB accounts
- Use ORMs safely (still validate queries)

Conclusion:

SQL Injection is one of the most critical and preventable web security vulnerabilities. It allows attackers to manipulate database queries, leading to data theft, authentication bypass, and even full system compromise. The best defense is secure coding: always use parameterized queries, validate and sanitize inputs, enforce least privilege on database accounts, and regularly test applications. With consistent security practices and awareness, SQL Injection can be effectively eliminated from modern applications.

THANK YOU